

Security Fundamentals · Section 6

Passwords and Authentication

By TOUCH DEN · November 11, 2026

Contents

What You Will Learn 1

Before You Start 1

1. What Authentication Is 1

2. The Three Factors 2

3. Why Passwords Fail 2

4. How Passwords Are Stored and Cracked 3

5. Making Strong Passwords and Passphrases 3

6. Password Managers 4

7. Multi-Factor Authentication 4

8. Passkeys: The Direction of Travel 5

Common Mistakes 5

Summary 6

Check Your Understanding 6

Practice 7

What You Will Learn

- What authentication is, and the three factors it can use.
- Why passwords fail so often.
- How passwords are stored and cracked, and why storage matters.
- How to make strong passwords and passphrases.
- Why a password manager is one of the best security habits.
- What multi-factor authentication is, and why it defeats most attacks.
- What passkeys are, and why they are the direction of travel.

Before You Start

Read lessons 1 to 5. Lesson 2 introduced authentication as part of AAA; lesson 5 showed how passwords are attacked. This lesson is the practical core: the habits here protect you more than almost anything else you will learn. No programming is needed.

---

1. What Authentication Is

Authentication is proving that you are who you say you are. It is the lock on the front door of almost every system: before it lets you read or change anything, it checks your identity.

Keep two words apart, from lesson 2:

- **Identification** is claiming an identity ("I am Dara"), usually a username.
- **Authentication** is proving it ("and here is my password / fingerprint / code").

A username is not a secret; it is often an email address. The secret is the proof. So the whole strength of a login rests on how good that proof is, which is what this lesson is about.

2. The Three Factors

There are three fundamentally different kinds of proof, called **factors**:

Factor	Meaning	Examples
Something you know	A secret in your head	Password, PIN, the answer to a question
Something you have	A physical thing you possess	A phone, a security key, a bank card
Something you are	A physical trait of your body	Fingerprint, face, voice

Each has weaknesses. Something you **know** can be guessed, phished, or reused. Something you **have** can be lost or stolen. Something you **are** cannot be changed if it leaks, and can sometimes be copied.

The power comes from **combining** factors, which we return to in topic 7. If a login needs two different factors, an attacker must beat both, and beating a password is very different from stealing your phone. Using two of the same kind (two passwords) is not nearly as strong, because one attack, phishing, can take both.

3. Why Passwords Fail

Passwords are the oldest and most common factor, and the most troublesome. They fail for human and technical reasons:

- **People choose weak ones.** "123456" and "password" top every leaked-password list, year after year.
- **People reuse them.** The same password across many sites means one breach unlocks them all (credential stuffing, lesson 5).
- **People can be tricked into giving them away.** A password is just words, so a convincing fake login page collects it in seconds.
- **They can be guessed in bulk.** Computers try billions of guesses against a stolen password file.
- **We have too many.** A person may have hundreds of accounts, far more than anyone can remember with unique strong passwords, so they cut corners.

None of this means passwords are useless. It means a password alone is weak, and must be made strong (topics 5 and 6) and backed by a second factor (topic 7). The long-term answer, passkeys, removes the password entirely (topic 8).

4. How Passwords Are Stored and Cracked

To check your password, a system must store something to compare against. How it stores that something decides what happens when the store is stolen, and stores are stolen often.

- ***The worst way: plain text.*** *The password is saved as-is. If the file leaks, every password is instantly exposed. No competent system does this, but some still do.*
- ***The right way: hashing.*** *The system stores a* ***hash****, a scrambled fingerprint produced by a one-way function. You can turn a password into its hash, but you cannot turn the hash back into the password. At login, the system hashes what you typed and compares the two hashes.*

Hashing is not perfect on its own. Attackers who steal a file of hashes crack it ***offline****, guessing passwords, hashing each guess, and looking for a match, at billions of guesses a second. Two techniques make this much harder:*

- ***Salting:*** *adding a unique random value to each password before hashing, so identical passwords get different hashes and attackers cannot crack them all at once with precomputed tables.*
- ***Slow hashing:*** *using a function built to be deliberately slow (such as bcrypt, scrypt, or Argon2), so each guess costs real time, turning billions of guesses a second into a few thousand.*

You do not need the math yet; the Cryptography course covers it. The takeaway for now: ***a strong password matters because storage can be stolen, and good storage, salted slow hashing, matters because it buys time to respond even if it is.*** *This is also why a long password helps so much: each extra character multiplies the number of guesses an attacker must make.*

5. Making Strong Passwords and Passphrases

What makes a password hard to crack is not mostly strange symbols; it is ***length and unpredictability****. A short password full of symbols can be weaker than a long, simple one.*

- ***Length wins.*** *Every extra character multiplies the work to guess it. Aim for at least 12–16 characters where you must remember it.*
- ***Passphrases are strong and memorable.*** *Four or five random, unrelated words, like* `correct-harbor-tiger-bottle`*, are long, easy to recall, and very hard to guess, as long as the words are truly random and not a famous phrase.*
- ***Unpredictable, not just complex.*** `P@ssw0rd!` *looks complex but is one of the first things cracking tools try, because the substitutions are obvious. Randomness beats cleverness.*

- ***Unique per site.*** *Even a strong password is dangerous if reused, because one breached site exposes it everywhere.*
- ***Do not rely on forced "complexity rules".*** *Rules demanding a symbol and a number often push people to predictable patterns. Length and uniqueness matter more.*

Remembering a unique long password for every account is impossible by hand, which is exactly the problem a password manager solves.

6. Password Managers

*A **password manager** is an app that generates, stores, and fills in a different strong password for every account. You remember **one** strong master password (or unlock it with your fingerprint or face), and it remembers all the rest, encrypted.*

Why it is one of the best security habits you can adopt:

- *It makes **unique, long, random** passwords effortless, defeating reuse and guessing at once.*
- *It **fills passwords only on the correct site**, which quietly defends against phishing: if the site is a fake look-alike, the manager will not recognize it and will not fill in your password.*
- *It lets you **see and change** weak or reused passwords across all your accounts.*

*Common worries, answered: a reputable manager stores everything **encrypted**, so even its own company cannot read your passwords; and keeping them in one well-protected, encrypted vault is far safer than the realistic alternative, reusing a handful of weak passwords everywhere, or writing them on paper. Protect the manager itself with a strong master password and multi-factor authentication.*

7. Multi-Factor Authentication

***Multi-factor authentication (MFA)**, also called two-factor (2FA) or two-step verification, requires **two different factors** to log in: usually something you know (your password) plus something you have (a code on your phone, or a tap on a security key).*

It is the single most effective step most people and businesses can take, because it breaks the most common attacks. A stolen or guessed password is now useless on its own: the attacker also needs your second factor. Credential stuffing, most phishing, and bulk password cracking all fail against MFA.

Not all second factors are equal:

- ***SMS codes** (texted to your phone) are common and far better than nothing, but can be intercepted or redirected, so they are the weakest MFA.*

- **Authenticator apps** that generate a changing 6-digit code are stronger and work offline.
- **Security keys** (small hardware devices) and **passkeys** (topic 8) are the strongest, because they also verify the site and cannot be phished.

Turn MFA on everywhere it is offered, starting with the accounts that matter most: email (which can reset all your other passwords), banking, and work. One caution: some phishing now tries to trick you into approving an MFA prompt or handing over a code, so treat an unexpected prompt as a warning, never approve one you did not start.

8. Passkeys: The Direction of Travel

The newest and most promising answer removes the password altogether. A **passkey** is a secret that lives on your device (your phone or computer) and proves your identity without ever sending a password to the site. You unlock it the way you unlock your phone, with your fingerprint, face, or PIN.

Why passkeys are better:

- **Nothing to phish.** There is no password to type, so there is nothing for a fake site to steal. The passkey also checks it is talking to the real site.
- **Nothing to reuse or leak in a breach.** Each passkey is unique to one site, and the site never stores a secret that could be stolen and cracked.
- **Easy to use.** Signing in is just unlocking your device, which is faster than typing a password.

Passkeys are built on well-tested public-key cryptography (the Cryptography course explains how) and are supported by the major platforms and a growing number of websites. They are the direction the whole industry is moving. For now, the practical advice is layered: use a password manager for unique strong passwords, turn on MFA everywhere, and adopt passkeys wherever a site offers them. Lesson 7 continues the story: once a system knows who you are, how it decides what you are allowed to do.

Common Mistakes

1. Confusing identification with authentication. A username is a claim, not a secret. The password (or key) is the proof, and it is what must be strong.

2. Reusing passwords. The biggest single password mistake. One breached site exposes every account that shares the password.

3. Choosing complex over long. `P@ssw0rd!` *is weaker than a long passphrase. Length and unpredictability beat obvious symbol tricks.*

4. Storing passwords in plain text (as a builder). *If the store leaks, every password is instantly exposed. Always use salted, slow hashing.*

5. Refusing a password manager out of fear. *A reputable, encrypted manager is far safer than the reuse and weak passwords people fall back on without one.*

6. Treating all MFA as equal. *SMS is the weakest; authenticator apps, security keys, and passkeys are stronger. Any MFA still beats none.*

7. Approving an MFA prompt you did not start. *That is now a common attack. An unexpected prompt is a warning, not a convenience.*

Summary

Term	Remember
Authentication	*Proving you are who you claim to be*
The three factors	*Something you know / have / are*
Why passwords fail	*Weak, reused, phishable, guessable, too many*
Hashing / salting / slow hashing	*How passwords should be stored, so a stolen file resists cracking*
Strong passwords	*Long and unpredictable beats short and complex; unique per site*
Password manager	*One master password; unique strong passwords for all; anti-phishing*
MFA	*Two different factors; defeats stolen passwords; SMS weakest*
Passkeys	*Passwordless, unphishable, unique per site; the future*

Check Your Understanding

1. *What is the difference between identification and authentication?*
2. *Name the three factors, with an example of each.*
3. *Why is reusing a password so dangerous?*
4. *Why does it matter whether a site stores passwords as plain text or as salted, slow hashes?*
5. *Which is usually stronger: a short password with many symbols, or a long passphrase of random words? Why?*
6. *Give two reasons a password manager improves security.*
7. *Why does MFA defeat a stolen password, and which MFA method is the weakest?*

8. *In one sentence, why is a passkey hard to phish?*

Answers

1. *Identification is claiming an identity (a username); authentication is proving it (a password, code, or key). The proof is the secret part.*
2. *Something you know (password/PIN); something you have (phone/security key); something you are (fingerprint/face).*
3. *Because a breach of one site exposes that password, and attackers then try it on all your other accounts (credential stuffing). One leak unlocks many accounts.*
4. *If stored as plain text, a leak exposes every password instantly. Salted, slow hashing means a stolen file is slow and hard to crack, buying time to respond.*
5. *The long passphrase, usually. Length multiplies the guesses needed, while a short password's obvious symbol tricks are the first things cracking tools try.*
6. *Any two: it makes unique long random passwords effortless; it fills passwords only on the correct site, defending against phishing; it lets you find and fix weak or reused passwords.*
7. *Because the attacker also needs your second, different factor (such as your phone), which a stolen password does not provide. SMS codes are the weakest MFA.*
8. *A passkey never sends a password and verifies it is talking to the real site, so a fake site has nothing to capture and cannot impersonate the real one.*

Practice

A practical lesson deserves a practical exercise. Do these for real, on your own accounts:

1. *List your **three most important accounts** (usually email, banking, and one more).*
2. *For each, check whether **MFA** is turned on. If not, and it is offered, turn it on, starting with email.*
3. *Decide on a **password manager** to try, and plan to move your reused passwords into unique ones, most important accounts first.*

Then answer in writing: which single one of your accounts, if an attacker took it over, would let them reach the most other accounts? (For most people it is email, because it can reset other passwords, which is why it should get the strongest protection first.)

A Worked Example

1. *Most important: email, mobile banking, and a social media account tied to my real name.*
2. *Email: MFA was off, now on with an authenticator app. Banking: MFA already on via the bank app. Social media: turned on with an authenticator app.*

3. Chose a reputable password manager; plan to change email and banking to unique 16-character generated passwords first, then work through the rest.

The account that reaches the most others: email, because password resets for almost everything land there, so it gets an authenticator-app second factor and a unique strong password before anything else.

Course mark icon from Material Symbols by Google, Apache License 2.0. NIST, CIS, ISO, OWASP, and MITRE ATT&CK are the trademarks of their respective owners, used here only to refer to their published work.